

MINI PROJECT

INFORMATION SECURITY MANAGEMENT SYSTEM (ISMS)

- AIDA YUSREENA BINTI ABD HALIM (52215123089)
- AMEERA MANSUR OMAR (52215123202)
- ARISA SUFIANI BINTI ADIE SUFIAN (52215123361)
- NUR ERINA FALISHA BINTI MAZLAN (52215123182)



Agenda



01

Brief Introduction

02

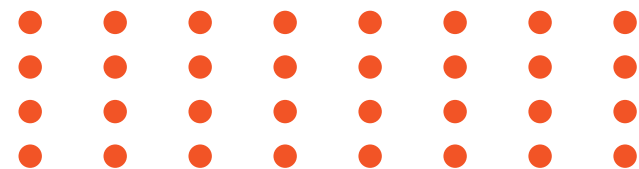
Risk Determination

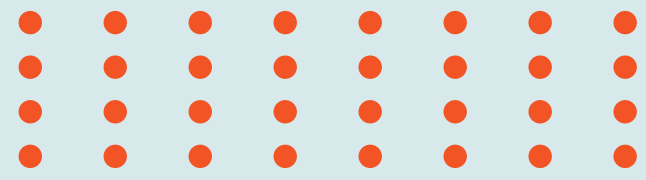
03

Results and Findings

04

Countermeasures





Brief Introduction



Kuala Lumpur International Airport Terminal 1 (KLIA1) is a high-traffic international airport where secure operations and IT infrastructure are critical. This audit focuses on assessing **physical security controls** to prevent unauthorized access and protect sensitive areas.

The **scope** includes:

- Network rooms
- Security pass counters
- Airport pass offices
- Departure gates
- Emergency exits
- Building entrances
- Public areas around the terminals.

The audit used guided **site observations** and **informal staff interviews** to **identify security gaps**, **evaluate risks**, and **recommend practical measures** to strengthen physical security and ensure operational continuity.

Risk Determination



Risk Identification:

- What needs protection?
 - What can go wrong?
 - Why are threat is possible?
-

Risk Criteria :

- Impact measurement scales (financial, safety, and legal impact)
 - Likelihood assessment methodology
 - Risk evaluation matrix parameters
-

Risk Assessment Methodologies: Qualitative method

- Likelihood is determined based on a scale of 1-5
- Impact is measured through financial, safety, and legal impact
- Calculation of risk level: Likelihood x Impact
- Risks are categorized by low, medium, high, and extreme

Likelihood Description

Likelihood	Rating	Description	Probability of Occurrence
Almost certain	5	- The risk is almost certain to occur due to high exposure to risk, ineffective controls, or insufficient preventive measures	Greater than 1 in 20 occurrences
Likely	4	- The risk is likely to happen, with prior evidence or weaknesses indicating increased vulnerability - Past data shows failures in similar designs or systems	Between 1 in 20 and 1 in 200 occurrences
Possible	3	- The risk may occur under specific conditions, such as a breach in control or system failure - Controls are in place, but may not fully prevent the failure	Between 1 in 200 and 1 in 2000 occurrences
Unlikely	2	- The risk is unlikely but could occur under specific conditions - Controls are in place, but not fully foolproof	Between 1 in 2000 and 1 in 10000 occurrences
Rare	1	- The risk of failure or occurrence is highly improbable - Strong physical security controls and preventive measures are in place	Less than 1 in 10000 occurrences

Impact Description

Consequence	Rating	Description	Operational Effect	Safety and Legal Effect
Catastrophic	5	Critical impact, causing a complete failure in physical security, leading to severe operational, financial, and legal consequences	- Complete operational failure - For example, widespread access issues, a complete security breach	- Major legal consequences - Death, serious injury, or severe regulatory violations occur
Major	4	Significant impact on physical security, leading to operational delays or breakdowns of critical systems or areas	- Major disruption - For example, a complete shutdown of access control systems, restricted area vulnerabilities	- Serious safety or legal consequences - Regulatory violations, injuries, or lawsuits occur
Moderate	3	- Noticeable impact on physical security - Operations are disrupted for a period, leading to moderate recovery efforts	- Moderate disruption - For example, hours of downtime at access points, partial failure in physical security controls	- Legal or safety concerns - Non-compliance with safety regulations, minor injuries
Minor	2	- Low impact on physical security operations - The issue may cause small delays or minor disruption but can be quickly resolved	- Minor delays - For example, access points are temporarily blocked, minor breakdowns in system functionality	- Minor safety issues, such as small slips or falls - Legal concerns may arise, but not significantly.
Insignificant	1	- Minimal or no impact on physical security operations - The incident has little or no effect on the overall system	- No disruption to operations - Access to restricted areas continues without interruption.	- No safety concerns - No legal consequences.

Matrix of Risk

		Consequence				
		1 Insignificant	2 Minor	3 Moderate	4 Major	5 Catastrophic
Likelihood	5 Almost certain	5 - Low	10 - Medium	15 - High	20 - Extreme	25 - Extreme
	4 Likely	4 - Low	8 - Medium	12 - High	16 - High	20 - Extreme
	3 Possible	3 - Low	6 - Medium	9 - Medium	12 - High	15 - High
	2 Unlikely	2 - Low	4 - Low	6 - Medium	8 - Medium	10 - Medium
	1 Rare	1 - Low	2 - Low	3 - Low	4 - Low	5 - Low

Explanation of the likelihood value × consequence scoring:

- Score 1-5 = Low
- Score 6-10 = Medium
- Score 11-16 = High
- Score 17-25 = Extreme

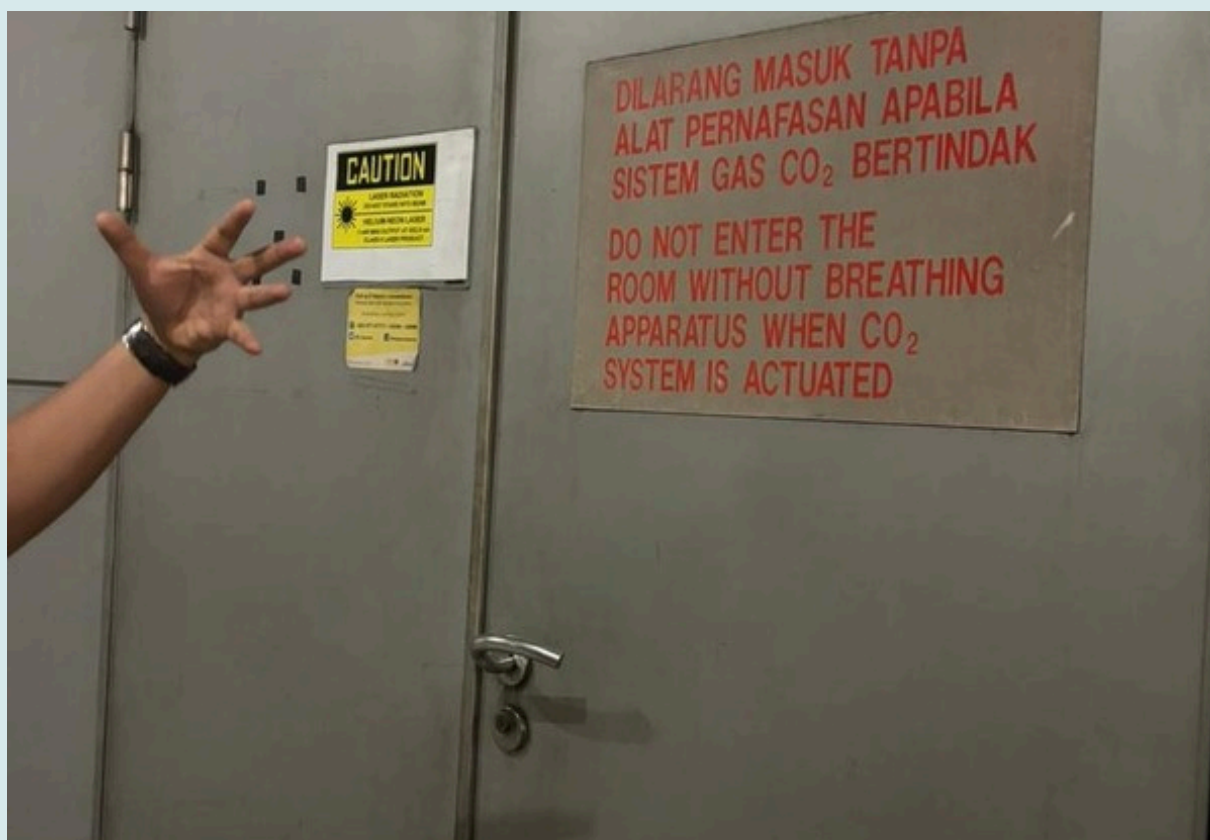
	Green represents low risk (Accept)
	Yellow represents medium risk (Accept or Treat)
	Orange represents high risk (Treat)
	Red represents extreme risk (Treat immediately)

Result & Findings

The findings that were identified during the audit are as follows:

1. Inadequate Physical Access Control for Network Room
2. CCTV Coverage Concentrated in Main Public Areas
3. Restricted Accessibility of Emergency Exit Doors
4. Lack of Active Security Personnel at Building and Perimeter Entrances
5. Inconsistent Use of Employee Identification Badges
6. Infrequent Review of Physical Access Rights
7. Limited Frequency of Physical Security Awareness Training
8. Absence of a Formal Escort Policy for Third-Party Access
9. Absence of Access Enforcement Against Tailgating





Finding 1: Inadequate Physical Access Control for Network Room

Finding:

During the physical security walkthrough at KLIA1, the network room was observed to be protected using only a card-based access control system. No biometric authentication or secondary verification mechanism was implemented at the entrance. Access to the network room relied solely on possession of an authorised access card.

Evidence:

Direct observation during the site visit showed that a card access reader was installed at the network room entrance, with no biometric scanner, keypad, or additional authentication device present. This indicates that physical access control for the network room is limited to single-factor authentication.

Finding 2: CCTV Coverage Concentrated in Main Public Areas

Finding:

During the physical security walkthrough at KLIA1, CCTV cameras were observed to be primarily installed in main or common public areas with high passenger movement. Surveillance coverage in secondary corridors and less frequented areas appeared limited in comparison to central public spaces.

Evidence:

Direct observation during the site visit confirmed the presence of CCTV cameras in common areas of the terminal. Informal interview responses and the physical security audit checklist further indicate that surveillance deployment prioritises high-traffic public zones.



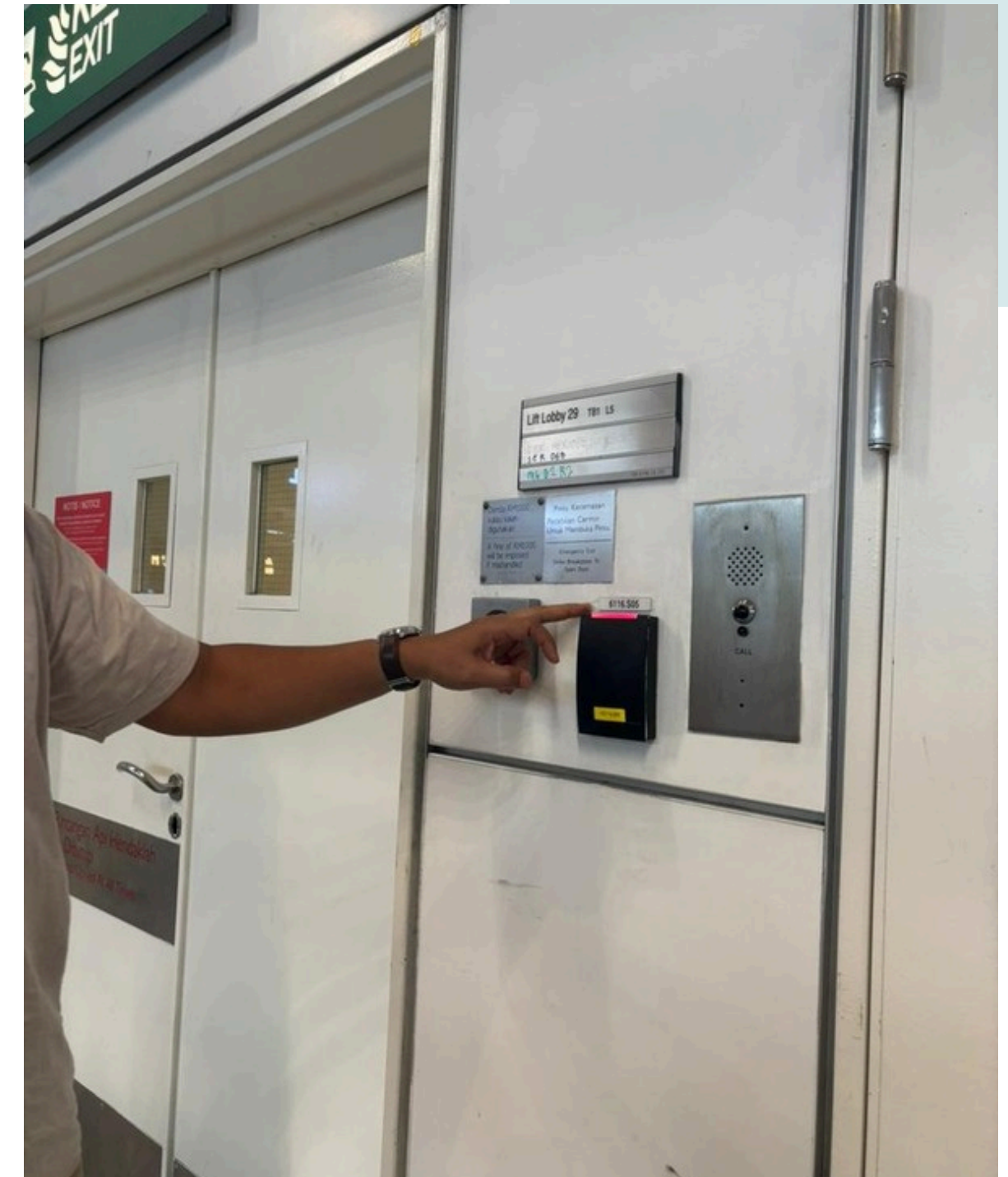
Finding 3: Restricted Accessibility of Emergency Exit Doors

Finding:

During the physical security walkthrough at KLIA1, certain emergency exit doors were observed to be fitted with access control mechanisms that restrict usage to authorised personnel. While access control was present, the emergency exits observed did not appear to be freely accessible for immediate use by all occupants.

Evidence:

Direct observation during the site visit confirmed that selected emergency exit doors required access authorisation to open. The physical security audit checklist also reflects the presence of controlled access mechanisms at emergency exits within the audited areas.



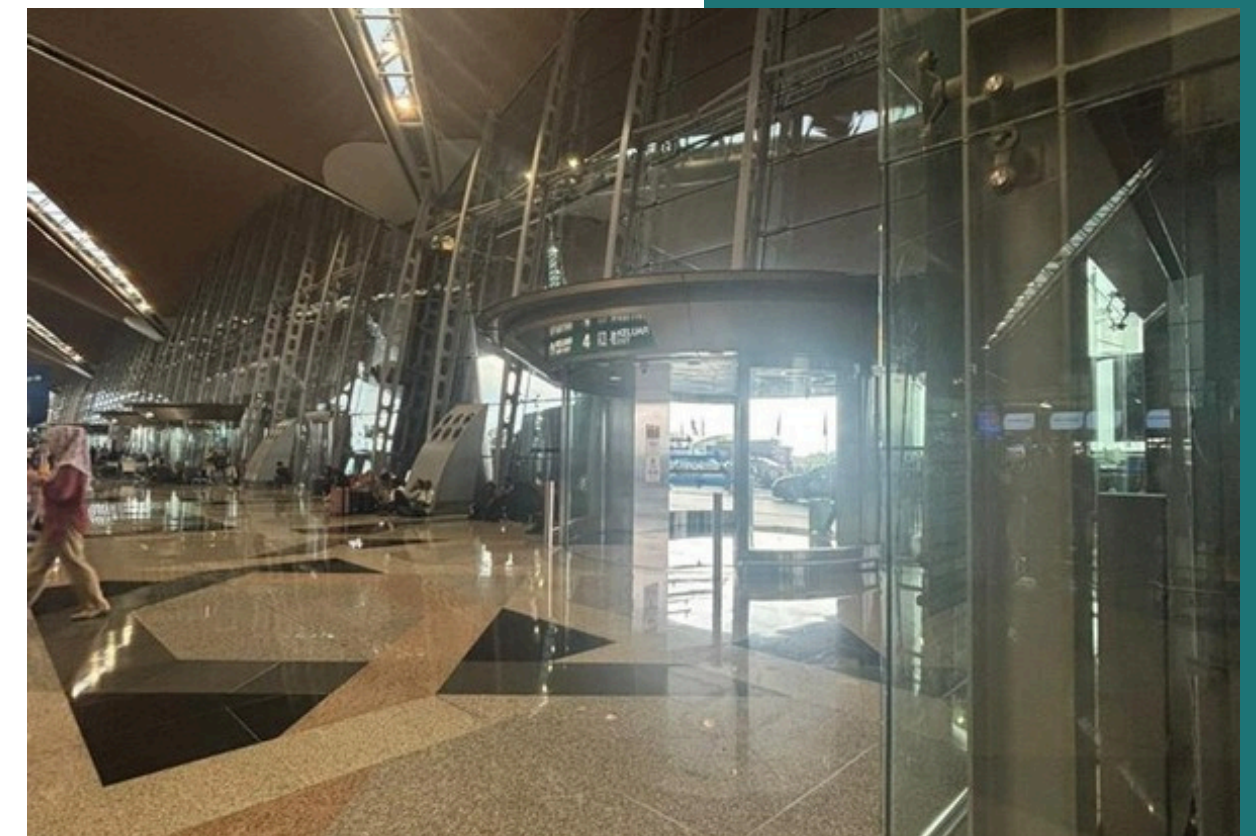
Finding 4: Lack of Active Security Personnel at Building and Perimeter Entrances

Finding:

During the physical security walkthrough at KLIA1, selected building and perimeter entrances were observed to operate without an actively stationed security presence. Access at these entry points appeared to rely mainly on passive measures, with no visible security personnel present to monitor, verify, or challenge individuals entering the premises.

Evidence:

Direct observation during the site visit confirmed that both a perimeter access point and a main entrance area were accessible without on-site security guards stationed at the entry points. This indicates reliance on passive access control rather than active human monitoring at selected entrances.



Finding 5: Inconsistent Use of Employee Identification Badges

Finding:

During the physical security walkthrough at KLIA1, employees were observed not consistently wearing identification badges while operating within working areas. The absence of visible identification makes it more difficult for security personnel and staff to distinguish authorised employees from unauthorised individuals, particularly in busy operational environments.

Evidence:

This finding is supported by direct observation during the site visit, where identification lanyards were not visibly worn by all employees at all times. In addition, the physical security audit checklist indicates inconsistent compliance with employee identification badge requirements, which may reduce the effectiveness of physical access monitoring.





Finding 6: Infrequent Review of Physical Access Rights

Finding:

During the physical security audit at KLIA1, physical access rights were found to be reviewed on an as-needed basis rather than through a regular and systematic review process. No evidence of scheduled or periodic access rights reviews was identified for employees or third-party personnel.



Evidence:

This finding is supported by information obtained during the site walkthrough and informal interview, which indicated that access privileges are reviewed only when specific changes or requests arise. The physical security audit checklist also reflects the absence of a documented or routine access review schedule.





Finding 7: Limited Frequency of Physical Security Awareness Training

Finding:

During the physical security audit at KLIA1, physical security awareness training was found to be conducted only once per year. No evidence of more frequent or refresher training sessions related to physical access control, badge usage, or security responsibilities was identified during the audit.



Evidence:

This finding is supported by information obtained through informal interviews and review of current practices, which indicated that physical security training is scheduled on an annual basis. The physical security audit checklist also reflects limited training frequency for staff in relation to physical security awareness.





Finding 8: Absence of a Formal Escort Policy for Third-Party Access

Finding:

During the physical security audit at KLIA1, no formal escort policy was identified for third-party personnel accessing IT-related or restricted areas. External personnel, such as cleaners, maintenance staff, or contractors, were observed to access certain areas without documented requirements for continuous supervision by authorised employees.



Evidence:

This finding is supported by direct observation during the site walkthrough and information obtained through informal interviews, which indicated the absence of a documented escort requirement for third-party personnel. The physical security audit checklist also reflects the lack of a formal escort policy for external access to restricted or IT-related areas.





Finding 9: Absence of Access Enforcement Against Tailgating

Finding:

During the physical security audit at KLIA1, weaknesses were identified in access enforcement against tailgating at various access-controlled locations, including building entrances, operational areas, and IT-related zones. Access to these areas was observed to rely primarily on access card usage, with limited additional verification or active supervision to prevent unauthorised individuals from following authorised personnel.

Evidence:

This finding is supported by direct observation during the site walkthrough, where access-controlled entry points were observed without active measures to prevent tailgating. Informal interview responses and the physical security audit checklist further indicate reliance on card-based access control without supplementary enforcement mechanisms or continuous monitoring.



Proposed Countermeasures

The proposed countermeasures address the physical security weaknesses identified at KLIA1 using a risk-based approach, focusing first on high-risk issues that could lead to unauthorized access, system compromise or safety hazards.



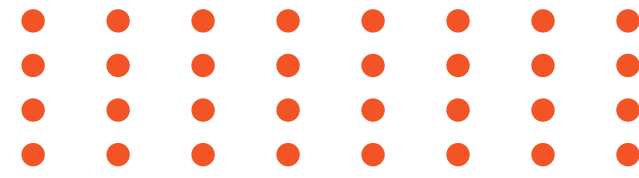
Proposed Countermeasures



Key Findings	Likelihood	Control Type	Proposed Countermeasure	Description
Inadequate physical access control for network room	High	Preventive	Strengthened restrictions on access of the network room	Prevent physical access to critical IT infrastructure without authorization
Absence of access enforcement against tailgating	High	Preventive	Implementation of anti-tailgating measures at all access-controlled entry points	Tailgating is likely happen in shared and high-traffic environments
Lack of active security personnel at building and perimeter entrances	High	Preventive	Security stationed at the main building and perimeter entrances	The likelihood of unauthorized access is very high without visible deterrents
CCTV coverage limited to public areas	Medium	Detective	Wider surveillance on non-public and restricted areas	Improves the chances of detection in situations where incidents could have gone unnoticed
Inconsistent use of employee identification badges	Medium	Preventive/Corrective	Visible employee identification made compulsory	The likelihood of misuse or impersonation without an obvious ID is medium



Proposed Countermeasures



Key Findings	Likelihood	Control Type	Proposed Countermeasure	Description
Absence of formal escort policy for third-party access	Medium	Preventive	- Assign third-party escort in restricted areas - Temporary identification badges for external personnel	Unsupervised third-party movement increases the risk of unauthorized access
Infrequent review of physical access rights	Medium	Corrective	Conduct physical access rights review periodically	Prevent accumulation of outdated or excessive privileges
Limited frequency of physical security awareness training	Medium	Corrective	Conduct physical security awareness training regularly	Repeated human errors will reduce over time
Restricted accessibility of emergency exit doors	Low	Preventive	Ensures emergency exits accessible all the time	The likelihood is low but high safety impact when emergency emerges

THANK
YOU